

PHARAOHS SECURITY TEAM

PENETRATION TEST REPORT

Internal Security Assessment

TARGET SYSTEM | 192.168.100.181 (Metasploitable 2)

ASSESSMENT TYPE | INTERNAL NETWORK PENETRATION TEST

OVERALL RISK RATING: CRITICAL

Prepared by Pharaohs Security Team

August 23, 2026 | CONFIDENTIAL

Report Control

Engagement reference, distribution, and assessment context

Client / Environment	Internal laboratory environment - Metasploitable 2
Target	192.168.100.181
Assessment type	Internal Network Penetration Test
Assessment date	August 23, 2026
Prepared by	Pharaohs Security Team
Classification	CONFIDENTIAL - intended for authorized stakeholders only
Overall risk	CRITICAL

Assessment Team

- Yehia Mohamed Amin
- Mariam Seddiq Motawaa
- Menna Ashraf Shaban
- Rana Khaled Khalifa
- Sama Tarek Ahmed

Handling Notice

This document records security observations from an authorized internal lab assessment. It contains sensitive technical risk information and should be distributed only to stakeholders responsible for remediation and risk acceptance.

Report Structure

- Executive summary and scope
- Vulnerability summary and risk assessment
- Evidence placeholders and remediation roadmap
- Technical findings 5.1 through 5.12

1. Executive Summary

Management overview

Pharaohs Security Team performed an internal network penetration test of 192.168.100.181, a Metasploitable 2 laboratory target. The objective was to identify materially exploitable weaknesses, validate their impact under controlled conditions, and provide prioritized remediation guidance.

The assessment followed reconnaissance, service enumeration, vulnerability identification, controlled exploitation validation, impact assessment, and reporting. Nmap, Metasploit Framework, Netcat, Curl, and Showmount supported the validation workflow.

Overall Security Posture

The target exhibits a **CRITICAL** security posture. Multiple legacy, exposed, and insecure services permitted plausible unauthorized access and system compromise. The combination of backdoored services, unauthenticated command execution paths, weak remote access controls, and exposed filesystem services creates numerous independent routes to high-impact compromise.

Business Impact

- Complete system compromise could enable unauthorized access to applications, credentials, and sensitive data.
- Remote command execution paths can support malware deployment, service disruption, privilege abuse, and lateral movement.
- Exposed database, NFS, and remote desktop services increase the likelihood of data loss and operational interruption.
- Immediate containment and remediation are warranted before the host is used in any connected environment.

Executive Conclusion

Successful controlled validation demonstrated that multiple critical vulnerabilities could allow unauthorized access and complete system compromise. Risk acceptance is not recommended without urgent compensating controls and a time-bound remediation plan.

2. Scope and Methodology

Authorized assessment approach

Scope

Target IP	192.168.100.181
System	Metasploitable 2
Network perspective	Internal network assessment
In scope	Network-reachable services and their security configuration
Out of scope	Persistence, data exfiltration, lateral movement, denial of service, and attacks on other hosts

Methodology

- **Reconnaissance** - identify the target and reachable network surface.
- **Service Enumeration** - fingerprint ports, protocols, versions, and exposed administration interfaces.
- **Vulnerability Identification** - correlate observed services with known weaknesses and unsafe configurations.
- **Exploitation Validation** - confirm impact in a controlled lab manner, limited to the evidence needed.
- **Impact Assessment** - document likely attacker capability and business consequence.
- **Reporting** - assign risk levels and deliver actionable remediation guidance.

Tools Used

Tool	Purpose
Nmap	Port, service, and version enumeration
Metasploit Framework	Controlled exploit validation
Netcat	Network connectivity and listener validation
Curl	HTTP service assessment
Showmount	NFS export discovery

3. Vulnerability Summary

Findings 1-6

Severity reflects the assessed likelihood and impact in the authorized internal context. CVSS scores are estimated and should be formally recalculated if deployed outside the laboratory.

ID	Vulnerability	Service	Port	Severity	Impact
1	VSFTPD 2.3.4 Backdoor RCE	FTP	21	Critical	Remote root access
2	Samba Usermap Script RCE	SMB	139 / 445	Critical	Remote command execution
3	UnrealIRCd 3.2.8.1 Backdoor	IRC	6667 / 6697	Critical	Remote code execution
4	DistCC Daemon Command Execution	DistCC	3632	Critical	Arbitrary command execution
5	Tomcat Manager Deployment RCE	Tomcat	8180	Critical	Remote code execution
6	Java RMI Remote Code Execution	Java RMI	1099	Critical	Remote system compromise

3. Vulnerability Summary

Findings 7-12

Critical findings require immediate action. High findings should be remediated promptly as part of a coordinated hardening effort.

ID	Vulnerability	Service	Port	Severity	Impact
7	PostgreSQL Payload Execution	PostgreSQL	5432	Critical	Database server compromise
8	VNC Weak Authentication Exposure	VNC	5900	High	Unauthorized remote desktop access
9	PHP CGI Argument Injection	Apache / PHP	80	Critical	Remote code execution
10	Bind Shell Exposure	Bind Shell	1524	Critical	Root shell access
11	Tomcat AJP Ghostcat	AJP	8009	High	Sensitive file disclosure
12	NFS Root Filesystem Export	NFS	2049	Critical	Filesystem exposure

5.1 VSFTPD 2.3.4 Backdoor Remote Code Execution

Technical finding

SEVERITY: **CRITICAL** CVSS (EST.): 10.0 (Estimated)

Affected service	FTP
Port(s)	21
Business impact	Remote root access
Validation method	Backdoor validation

Description

The exposed FTP service identified itself as VSFTPD 2.3.4, a version associated with a maliciously modified distribution that can expose an unauthenticated command channel.

Technical Details

Version and banner information were consistent with the affected release. Controlled validation confirmed that the service accepted the known backdoor trigger within the isolated lab scope.

Exploitation Summary

Metasploit Framework was used in a controlled lab workflow to validate remote code execution without conducting persistence, lateral movement, or data exfiltration.

Impact

An internal attacker could obtain root-level control of the host, alter system configuration, access data, and use the host as a pivot point.

Recommendation

Immediately retire the service or upgrade from trusted packages. Restrict FTP access, require encrypted alternatives, and verify software integrity against an approved baseline.

5.2 Samba Usermap Script Remote Code Execution

Technical finding

SEVERITY: **CRITICAL** CVSS (EST.): 9.8 (Estimated)

Affected service	SMB
Port(s)	139 / 445
Business impact	Remote command execution
Validation method	Metasploit validation

Description

The SMB service was consistent with a Samba configuration vulnerable to command execution through unsafe usermap script processing.

Technical Details

Service enumeration identified legacy SMB exposure on TCP 139 and 445. Validation confirmed the vulnerable code path without attempting post-exploitation actions.

Exploitation Summary

A framework-assisted validation was performed against the approved target only. The result demonstrated command execution at the service account context.

Impact

Remote command execution can enable credential access, host takeover, malware deployment, and lateral movement across the internal network.

Recommendation

Upgrade Samba to a supported release, remove unsafe usermap script settings, limit SMB to approved segments, and disable legacy protocols.

5.3 UnrealIRCd 3.2.8.1 Backdoor

Technical finding

SEVERITY: **CRITICAL** CVSS (EST.): 9.8 (Estimated)

Affected service	IRC
Port(s)	6667 / 6697
Business impact	Remote code execution
Validation method	Backdoor validation

Description

The IRC daemon presented a version associated with a known supply-chain backdoor that permits unauthenticated command execution.

Technical Details

Banner enumeration identified UnrealIRCd 3.2.8.1. The service behavior matched the known affected distribution in the assessment environment.

Exploitation Summary

A controlled exploit validation was performed with Metasploit. No persistence, user interaction, or external communication was attempted.

Impact

An attacker who can reach the IRC service may execute operating-system commands and gain a foothold without valid credentials.

Recommendation

Remove the affected daemon, rebuild from a verified source, rotate service credentials, and restrict IRC services through internal firewall policy.

5.4 DistCC Daemon Command Execution

Technical finding

SEVERITY: **CRITICAL** CVSS (EST.): 9.8 (Estimated)

Affected service	DistCC
Port(s)	3632
Business impact	Arbitrary command execution
Validation method	Protocol validation

Description

The distributed compiler daemon was exposed to the internal network without authentication, enabling arbitrary command execution through the compilation protocol.

Technical Details

TCP 3632 was reachable and service fingerprinting identified DistCC. The daemon accepted an authorized test request consistent with command execution capability.

Exploitation Summary

Validation used a controlled request to demonstrate impact only; it did not alter files, establish persistence, or access adjacent systems.

Impact

An unauthenticated network user could execute system commands and potentially escalate to full host compromise.

Recommendation

Disable DistCC where it is not required. If retained, bind it to localhost or a tightly controlled build segment and enforce host-based firewall rules.

5.5 Apache Tomcat Manager Deployment RCE

Technical finding

SEVERITY: **CRITICAL** CVSS (EST.): 9.8 (Estimated)

Affected service	Tomcat
Port(s)	8180
Business impact	Remote code execution
Validation method	Manager deployment validation

Description

The Tomcat Manager interface was accessible on an alternate HTTP port and exposed a deployment path that can permit server-side code execution when weak or default credentials are present.

Technical Details

Enumeration identified the manager endpoint over TCP 8180. Authentication posture and deployment capability were assessed in the lab environment.

Exploitation Summary

Metasploit was used to validate the deployment-based execution path under controlled conditions, without changing production-like application content.

Impact

Successful deployment of a malicious application archive can give an attacker durable access to the web server and applications hosted on it.

Recommendation

Remove Manager from non-administrative exposure, enforce strong unique credentials and MFA where possible, restrict management IPs, and keep Tomcat patched.

5.6 Java RMI Remote Code Execution

Technical finding

SEVERITY: **CRITICAL** CVSS (EST.): 9.8 (Estimated)

Affected service	Java RMI
Port(s)	1099
Business impact	Remote system compromise
Validation method	RMI enumeration validation

Description

The Java Remote Method Invocation registry was exposed to the internal network, creating a high-risk interface for unsafe remote object interactions.

Technical Details

Service enumeration confirmed a reachable RMI registry on TCP 1099. The exposed registry information supported the feasibility of remote attack paths.

Exploitation Summary

Controlled validation was limited to registry enumeration and proof of reachable attack surface; no unsafe deserialization payloads were executed.

Impact

A vulnerable RMI implementation can permit remote code execution, compromise application secrets, and provide a pathway to full host control.

Recommendation

Restrict RMI to trusted application hosts, update Java and application frameworks, disable remote class loading, and enforce network-level allowlists.

5.7 PostgreSQL Payload Execution

Technical finding

SEVERITY: **CRITICAL** CVSS (EST.): 9.8 (Estimated)

Affected service	PostgreSQL
Port(s)	5432
Business impact	Database server compromise
Validation method	Authenticated execution validation

Description

The PostgreSQL service was reachable from the assessed internal segment and configured in a manner that could support server-side payload execution after authentication or credential compromise.

Technical Details

TCP 5432 was identified during enumeration. Service exposure and authentication controls were reviewed against common server-side execution risks.

Exploitation Summary

A controlled assessment workflow validated the security impact in the lab without modifying business data or retaining database access.

Impact

Compromise of the database service could expose sensitive records, allow server-side command execution, and disrupt application availability.

Recommendation

Restrict database listener exposure, use strong least-privilege roles, remove unnecessary extensions and superuser access, and monitor privileged database activity.

5.8 VNC Weak Authentication Exposure

Technical finding

SEVERITY: **HIGH** CVSS (EST.): 8.1 (Estimated)

Affected service	VNC
Port(s)	5900
Business impact	Unauthorized remote desktop access
Validation method	Authentication review

Description

The VNC service was reachable over the internal network and lacked sufficient authentication hardening to provide confidence against unauthorized desktop access.

Technical Details

TCP 5900 was exposed and service enumeration confirmed VNC availability. The configuration presented a weak remote-access control surface.

Exploitation Summary

Testing was limited to service discovery and controlled authentication posture assessment; no interactive desktop session was retained.

Impact

A successful attacker could view and control the desktop, access local files, capture credentials, and operate under the user context.

Recommendation

Disable VNC if not essential. Otherwise require strong unique credentials, encrypted tunnels, source IP restrictions, account lockout, and monitored access.

5.9 PHP CGI Argument Injection

Technical finding

SEVERITY: **CRITICAL** CVSS (EST.): 9.8 (Estimated)

Affected service	Apache / PHP
Port(s)	80
Business impact	Remote code execution
Validation method	HTTP request validation

Description

The web server exposed a PHP CGI configuration associated with argument injection, allowing crafted requests to influence PHP runtime behavior.

Technical Details

HTTP enumeration identified Apache/PHP exposure. The reachable handler and response characteristics were consistent with the vulnerable CGI attack surface.

Exploitation Summary

A safe validation request was used to confirm the condition in the lab. No web-shell deployment, file modification, or application data access was performed.

Impact

An unauthenticated attacker could execute commands through the web server, steal application secrets, deface content, or use the host as a pivot.

Recommendation

Upgrade PHP and Apache, disable CGI where unnecessary, use supported FPM configurations, enforce WAF controls, and review web service permissions.

5.10 Bind Shell Exposure

Technical finding

SEVERITY: **CRITICAL** CVSS (EST.): 10.0 (Estimated)

Affected service	Bind Shell
Port(s)	1524
Business impact	Root shell access
Validation method	Connection validation

Description

A bind shell was exposed on TCP 1524, representing an intentionally dangerous remote administration interface with no acceptable business justification.

Technical Details

Network enumeration detected an open listener consistent with a bind shell. The endpoint was reachable from the internal test segment.

Exploitation Summary

A controlled connection was used solely to confirm shell exposure and associated privilege level. No commands affecting system state were executed.

Impact

Any reachable attacker could gain immediate command-line access, potentially at root privilege, with no need to exploit another vulnerability.

Recommendation

Remove the bind shell immediately, investigate the host for compromise, rebuild from a known-good image, rotate credentials, and add detection coverage.

5.11 Apache Tomcat AJP Ghostcat

Technical finding

SEVERITY: **HIGH** CVSS (EST.): 7.5 (Estimated)

Affected service	AJP
Port(s)	8009
Business impact	Sensitive file disclosure
Validation method	AJP exposure validation

Description

The AJP connector was exposed and presented the file-read risk commonly associated with Ghostcat when required secrets or access controls are not enforced.

Technical Details

TCP 8009 was reachable and identified as AJP. The service exposure created an unnecessary internal attack surface for connector-level requests.

Exploitation Summary

The assessment validated exposure and risk indicators only. No confidential application files were retrieved beyond the minimum necessary to confirm scope.

Impact

An attacker may retrieve sensitive application files, configuration data, or use file disclosure to support a subsequent compromise.

Recommendation

Disable AJP if unused. Otherwise bind it to localhost, require a strong connector secret, upgrade Tomcat, and limit network reachability.

5.12 NFS Root Filesystem Export

Technical finding

SEVERITY: **CRITICAL** CVSS (EST.): 9.8 (Estimated)

Affected service	NFS
Port(s)	2049
Business impact	Filesystem exposure
Validation method	Showmount validation

Description

NFS exports exposed filesystem paths to the internal network with controls insufficient to protect sensitive system content or prevent privilege abuse.

Technical Details

Showmount and service enumeration identified reachable NFS exports over TCP 2049. Export configuration exposed a high-value pathway to the target filesystem.

Exploitation Summary

Controlled lab validation confirmed export availability only. Mounting and review were restricted to the minimum evidence required for the report.

Impact

An attacker could access sensitive files, abuse weak export permissions, obtain credentials, or modify content depending on export options.

Recommendation

Restrict exports to explicit trusted hosts, enable root squashing, use least-privilege permissions, remove nonessential exports, and monitor mount activity.

6. Risk Assessment

Risk classification and overall risk

Risk Matrix

Likelihood / Impact	Low	Moderate	High
High	Medium	High	Critical
Moderate	Low	Medium	High
Low	Low	Low	Medium

Classification and Overall Risk

Critical: 10 findings. High: 2 findings. No medium-severity findings were prioritized. The overall risk is **CRITICAL** because several independent paths could enable immediate compromise, system control, or material data exposure from the internal network.

7. Remediation Recommendations

Priority actions for risk reduction

Immediate Containment (0-7 days)

- Isolate or decommission the target until its critical exposure is eliminated.
- Disable unnecessary services, especially bind shell, DistCC, IRC, FTP, AJP, VNC, and exposed NFS exports.
- Apply firewall rules that deny unapproved internal access to administrative, database, and legacy service ports.
- Investigate the host for compromise indicators and rebuild from a trusted image where practical.

Remediation (7-30 days)

- Upgrade outdated operating systems and patch vulnerable services from trusted sources.
- Remove default credentials and implement strong, unique credential management.
- Secure database access through segmentation, least privilege, and restricted listeners.
- Restrict NFS exports to explicit hosts, enable root squashing, and remove nonessential paths.
- Implement network segmentation separating user, server, management, and build-service zones.

Sustained Assurance

- Conduct continuous vulnerability assessment and authenticated patch verification.
- Maintain an asset inventory, hardened service baselines, and centralized monitoring for privileged access.

8. Conclusion

The environment contains multiple critical security weaknesses. Controlled exploitation demonstrated that a malicious internal actor could plausibly achieve complete system compromise through several independent paths. Immediate remediation is required, with isolation and service removal prioritized before broader hardening and continuous assessment.